CRISC Exam - Domain 4: Technology & Security

Technology Risk Questions 43–82 with Explanations

Compiled from ISACA CRISC Review Manual 8th Edition

October 19, 2026

Outline

1. System Development Life Cycle
2. Data Life Cycle & Portfolio Management
3. Technology Resilience & Disaster Recovery

Q43: SDLC Purpose

Question

Why should effective management of systemic risk be accomplished through a rigorous, project-based approach to system development (SDLC)?

- A To eliminate the need for risk assessment
- B To ensure deliverables meet business needs and reduce systemic risk
- C To guarantee project success
- D To replace change management

Q43: Explanation

Correct Answer: B

Complex systems can deliver business value but also can be sources of significant risk. Effective management of systemic risk is best accomplished through a rigorous and comprehensive project-based approach to system development, commonly called an SDLC.

Option Analysis

- **A** - **Incorrect:** SDLC complements risk assessment
- **B** - **Correct:** SDLC reduces systemic risk
- **C** - **Incorrect:** No methodology guarantees success
- **D** - **Incorrect:** SDLC works with change management

Q44: SDLC - Initiation Phase

Question

During which SDLC phase is the need for an IT system expressed and endorsed by a sponsor, and the purpose and scope documented?

A. Initiation
B. Development or acquisition
C. Implementation
D. Operation or maintenance

Q44: Explanation

Correct Answer: A

In Phase 1 (Initiation), the need for an IT system is expressed and endorsed by a sponsor, and the purpose and scope of the anticipated IT system is documented. Risk identified within business processes is used to develop system requirements, including security requirements and a security concept of operations.

Option Analysis

- **A - Correct:** Initiation documents purpose and scope
- **B - Incorrect:** Development involves design and construction
- **C - Incorrect:** Implementation configures and tests security features
- **D - Incorrect:** Operation is when the system performs its functions

Q45: Security in SDLC

Question

Why should security requirements be addressed early in the SDLC?

A. Security is less important later in the project

B. It is considerably easier and less expensive to build security in at the onset than to add it later

C. Security requirements are only needed for external-facing systems

D. Security can always be added without additional cost

Q45: Explanation

Correct Answer: B

Security is a necessity in all modern business processes, and it is considerably easier and less expensive to address security requirements by building them into the project timeline at the onset than attempting to add them later. Security requirements should be specified, validated, and tested in the same manner as other requirements.

Option Analysis

- **A - Incorrect:** Security remains critical throughout
- **B - Correct:** Building security in early is cheaper and easier
- **C - Incorrect:** All systems require security
- **D - Incorrect:** Adding security later is more expensive

Q46: Key Security Tasks in SDLC

Question

Which of the following is a key security task to perform during the SDLC to document the risk associated with the development of a new program?

A. Only reviewing the final code
B. Security categorization of the proposed system and privacy impact assessment
C. Ignoring vendor security assessments
D. Skipping secure coding practices

Q46: Explanation

Correct Answer: B

Key security tasks during the SDLC include security categorization of the proposed system (CIA requirements and business impact), privacy impact assessment (sensitive data processed, applicable laws), vendor/supplier security or risk assessment, security training for development staff, and awareness of vulnerabilities in the selected technology.

Option Analysis

- **A - Incorrect:** Code review is one of many activities
- **B - Correct:** Security categorization and PIA are key tasks
- **C - Incorrect:** Vendor assessments are important
- **D - Incorrect:** Secure coding is mandated and enforced

Q47: Project Risk vs. System Risk

Question

What is the distinction between project risk and system risk?

A. There is no distinction; they are the same

B. Project risk deals with failing to deliver on time and within budget, while system risk relates to deliverables not meeting organizational needs

C. Project risk only applies to IT projects

D. System risk is only relevant after implementation

Q47: Explanation

Correct Answer: B

The risk practitioner should be aware of the distinction between project risk, which deals with the consequences of failing to deliver the promised results on time and within budget, and the risk that the deliverables may not meet the needs of the organization. Projects can deliver exactly what was requested yet fail because the original request was misguided.

Option Analysis

- **A - Incorrect:** There is a clear distinction
- **B - Correct:** Project risk vs. system risk
- **C - Incorrect:** Project risk applies to all projects
- **D - Incorrect:** System risk applies throughout the SDLC

Q48: Waterfall vs. Agile

Question

Which methodology is almost always better at delivering functionality of value to the user community?

A. Waterfall
B. Agile
C. Both are equally effective
D. Neither is effective

Q48: Explanation

Correct Answer: B

Because of their flexibility toward requirements, Agile methodologies are almost always better at delivering functionality of value to the user community. However, this flexibility makes controlling cost more complicated than under a Waterfall approach, where a precise understanding of what will be needed makes it possible to predict associated costs.

Option Analysis

- **A** - **Incorrect:** Waterfall is better for cost prediction
- **B** - **Correct:** Agile is better for delivering business value
- **C** - **Incorrect:** Each has distinct strengths
- **D** - **Incorrect:** Both are effective in different contexts

Q49: Changeover Techniques - Parallel

Question

Which changeover technique operates both the new and old systems simultaneously, providing the safest means of changeover if rollback is needed?

- A Parallel
- B Phased
- C Abrupt
- D Direct

Q49: Explanation

Correct Answer: A

Parallel changeover provides the safest and quickest means of changeover in case the changes need to be rolled back. Since the current system is fully operational, the new system can be stopped at any point where results are not as intended. Disadvantages include the cost of maintaining and monitoring both systems and ensuring data consistency.

Option Analysis

- **A - Correct:** Parallel runs both systems simultaneously
- **B - Incorrect:** Phased replaces individual components
- **C - Incorrect:** Abrupt is a single-instant movement
- **D - Incorrect:** Direct is not a standard changeover term

Q50: Changeover Techniques - Abrupt

Question

Which changeover technique is the riskiest due to the potential for lost business processing if reversion is needed?

- A Parallel
- B Phased
- C Abrupt
- D Incremental

Q50: Explanation

Correct Answer: C

Abrupt changeover is a single-instant movement from the old system to the new system, with the old system immediately taken offline. It is the riskiest of the changeover processes because of the potential for lost opportunities in business processing if it becomes necessary to revert to the earlier system. It is most prevalent when rollback is relatively assured or the impact of lost processing is minor.

Option Analysis

- **A - Incorrect:** Parallel is the safest
- **B - Incorrect:** Phased reduces risk by gradual rollout
- **C - Correct:** Abrupt is the riskiest
- **D - Incorrect:** Incremental is a form of phased

Q51: Data Migration Considerations

Question

Which of the following is a key consideration when migrating data from one system to another?

A. Data completeness, integrity, and consistency
B. Only the speed of migration
C. The color of the user interface
D. The number of project team members

Q51: Explanation

Correct Answer: A

Key data conversion considerations include completeness of data (verifying total records), data integrity (not altered except as required by conversion), storage and security of data under conversion, data consistency, and business continuity. The risk practitioner should assess the migration process to identify likely areas of concern.

Option Analysis

- **A - Correct:** Completeness, integrity, consistency
- **B - Incorrect:** Speed is secondary to data quality
- **C - Incorrect:** Interface color is irrelevant
- **D - Incorrect:** Team size is not a data consideration

Q52: Post-Implementation Review

Question

Why is a timely post-implementation review important after a project?

A. To assign blame for project failures

B. To capture lessons learned that can be applied to future projects

C. To immediately start the next project

D. To reduce the project budget

Q52: Explanation

Correct Answer: B

Whether an implementation project succeeds or fails, a timely post-implementation review offers the best opportunity to capture lessons learned so they can be applied to future projects. Questions include what went well, whether risk was brought within acceptable levels, whether requirements were met, and whether methodologies were followed.

Option Analysis

- **A - Incorrect:** Review is for learning, not blame
- **B - Correct:** Lessons learned for future projects
- **C - Incorrect:** Review is about reflection, not rushing ahead
- **D - Incorrect:** Review does not reduce budget

Q53: Data Life Cycle Phases

Question

Which of the following correctly lists the phases of the data management life cycle?

A. Create, store, use, share, archive, destroy
B. Identify, assess, respond, monitor
C. Plan, build, run, monitor
D. Budget, staff, train, audit

Q53: Explanation

Correct Answer: A

Data is commonly viewed as following a six-phase life cycle: create, store, use, share, archive, and destroy. In practice, this life cycle contains many caveats—creation may refer to original collection or synthesis from other data, and archiving or destruction may be mandated or prohibited by law or contract.

Option Analysis

- **A - Correct:** Create, store, use, share, archive, destroy
- **B - Incorrect:** These are risk management phases
- **C - Incorrect:** These are IT management phases
- **D - Incorrect:** These are management activities

Q54: Data Ownership Risk

Question

Why is a lack of clear data ownership a significant risk in the data life cycle?

- A. It makes it harder to verify what requirements apply and obtain approval for archiving, sharing, or destruction
- B. It improves data security
- C. It reduces storage costs
- D. It speeds up data processing

Q54: Explanation

Correct Answer: A

A lack of clear ownership of data makes it harder to verify what requirements apply to the data and obtain approval to take steps such as archiving, sharing, or destruction. The risk practitioner should review and assess the data ownership and management process, including protection from improper disclosure, modification, or deletion.

Option Analysis

- **A - Correct:** Unclear ownership hinders verification and approval
- **B - Incorrect:** Lack of ownership weakens security
- **C - Incorrect:** Ownership is unrelated to cost
- **D - Incorrect:** Ownership does not affect processing speed

Q55: Data Validation - Allowlist vs. Denylist

Question

Which data validation approach is preferred in environments where input data validation is based on static or infrequently changing values?

A. Denylist
B. Allowlist
C. Random sampling
D. Manual review

Q55: Explanation

Correct Answer: B

An allowlist is the preferred approach in environments where input data validation is based on static or infrequently changing values, where it is easier to anticipate what values would be reasonable than to anticipate what values might be malicious. A common library for allowlisting can ensure consistent data validation across multiple applications.

Option Analysis

- **A - Incorrect:** Denylists are useful when the range of valid values is extremely broad
- **B - Correct:** Allowlists are preferred for static values
- **C - Incorrect:** Random sampling is not a validation approach
- **D - Incorrect:** Manual review is not automated validation

Q56: Data Loss Prevention - False Positive

Question

What occurs when a data loss prevention (DLP) system incorrectly flags nonsensitive data as a potential data leak?

A. True positive
B. False positive
C. False negative
D. True negative

Q56: Explanation

Correct Answer: B

A false positive in DLP occurs when nonsensitive data is incorrectly flagged as a potential data leak. This can lead to disrupted workflows, wasted time for cybersecurity teams, and potentially lowered confidence in the DLP system. A false negative occurs when sensitive data is mistakenly allowed to leave the organization.

Option Analysis

- **A - Incorrect:** A true positive correctly identifies sensitive data
- **B - Correct:** Nonsensitive data incorrectly flagged
- **C - Incorrect:** A false negative misses sensitive data
- **D - Incorrect:** A true negative correctly allows nonsensitive data

Q57: Data Loss Prevention - False Negative

Question

What is the primary risk of a false negative in a data loss prevention (DLP) system?

A. Disrupted workflows

B. Sensitive data being mistakenly allowed to leave the organization

C. Wasted time for cybersecurity teams

D. Lowered confidence in the DLP system

Q57: Explanation

Correct Answer: B

A false negative in DLP occurs when sensitive data is mistakenly allowed to leave an organization, increasing the risk of data breaches or compliance violations. Disrupted workflows, wasted time, and lowered confidence are consequences of false positives, not false negatives.

Option Analysis

- **A - Incorrect:** This is a consequence of false positives
- **B - Correct:** Sensitive data leaves the organization
- **C - Incorrect:** This is a consequence of false positives
- **D - Incorrect:** This is a consequence of false positives

Q58: Project vs. Program

Question

What distinguishes a project from a program?

- A. A project has a defined end-state, while a program is an ongoing activity
- B. A program has a defined end-state, while a project is ongoing
- C. Projects are always larger than programs
- D. There is no distinction

Q58: Explanation

Correct Answer: A

A project is a series of tasks that work toward a common purpose with a defined end-state. Activities that continue indefinitely are considered programs, which may encompass one or more projects in the course of pursuing their recurring or ongoing goals.

Option Analysis

- **A - Correct:** Project has an end; program is ongoing
- **B - Incorrect:** The reverse is true
- **C - Incorrect:** Size is not the distinction
- **D - Incorrect:** There is a clear distinction

Q59: Project Failure Reasons

Question

Which of the following is a common reason IT projects fail?

- A Clear and stable requirements
- B Unclear or changing requirements and scope creep
- C Adequate resourcing
- D Effective communication

Q59: Explanation

Correct Answer: B

IT projects fail for various reasons, including unclear or changing requirements, addition of requirements without adequate resourcing (scope creep), inadequate access to resources, problems with technology, delays in delivery, unrealistic timelines, and lack of progress reporting or effective communication.

Option Analysis

- **A - Incorrect:** Clear requirements contribute to success
- **B - Correct:** Unclear requirements and scope creep cause failure
- **C - Incorrect:** Adequate resourcing contributes to success
- **D - Incorrect:** Effective communication contributes to success

Q60: Project Failure - Time, Quality, Cost Balance

Question

When a project team is struggling to remain on time and within budget, what is a common, dangerous shortcut?

- A Requesting additional resources
- B Skipping critical steps such as testing
- C Extending the timeline
- D Reducing project scope

Q60: Explanation

Correct Answer: B

Time, quality, and cost exist in a balance. A project team struggling to remain on time and within budget while maintaining access to necessary resources may skip critical steps such as testing to attempt to balance these priorities. Such actions create a temporary illusion of success but may lead to production failures, inaccurate reporting, or missing functionality.

Option Analysis

- **A - Incorrect:** Requesting resources is a positive approach
- **B - Correct:** Skipping testing is a dangerous shortcut
- **C - Incorrect:** Extending timeline is a legitimate option
- **D - Incorrect:** Reducing scope is a legitimate option

Q61: Portfolio Management Goal

Question

What is the primary goal of portfolio management?

A. To eliminate all projects

B. To optimize business value and create greater oversight under one accountable authority

C. To increase the number of projects

D. To reduce the IT budget

Q61: Explanation

Correct Answer: B

The goal of portfolio management is to optimize business value and create a greater degree of oversight under one accountable authority who is also appropriately empowered to solve problems as they arise. A single portfolio may include projects using different methodologies.

Option Analysis

- **A - Incorrect:** Portfolio management does not eliminate projects
- **B - Correct:** Optimize value and oversight
- **C - Incorrect:** Quantity is not the goal
- **D - Incorrect:** Budget reduction is not the primary goal

Q62: Cloud and Disaster Recovery

Question

How has the shift to cloud computing changed traditional disaster recovery responsibilities for customer enterprises?

A. Enterprises now have more control over recovery

B. Enterprises can often do nothing to recover until their cloud providers regain functionality

C. Disaster recovery is no longer needed

D. Enterprises now own all recovery infrastructure

Q62: Explanation

Correct Answer: B

Generally lacking hardware and other physical infrastructure of their own, cloud-reliant enterprises can generally do nothing to recover their operations until their hosts regain a level of operating capability sufficient to meet their expectations. Enterprises using software as a service will be unable to resume production until the software returns to normal operations.

Option Analysis

- **A** - **Incorrect:** Cloud generally reduces recovery control
- **B** - **Correct:** Enterprises wait for provider recovery
- **C** - **Incorrect:** Disaster recovery is still needed
- **D** - **Incorrect:** Cloud providers own the infrastructure

Q63: Most Important Role in Technology Resilience

Question

What is the most important role the risk practitioner can plan as it relates to technology resilience?

A. Personally recover all systems

B. Ensure the risk assumed through cloud technologies is well documented, fully understood, and formally accepted by management

C. Eliminate all cloud usage

D. Purchase additional insurance

Q63: Explanation

Correct Answer: B

The most important role that the risk practitioner can plan as it relates to technology resilience is to ensure that the risk assumed by the enterprise through its particular combination of cloud technologies and services is well documented, fully understood, and formally accepted by management.

Option Analysis

- **A - Incorrect:** Risk practitioners do not personally recover systems
- **B - Correct:** Document, understand, and accept cloud risk
- **C - Incorrect:** Eliminating cloud is often infeasible
- **D - Incorrect:** Insurance is one option, not the main role

Q64: SLA Misunderstanding

Question

What is a common misunderstanding about service level agreements (SLAs) in cloud environments?

A. SLAs guarantee uptime

B. SLAs ensure agreed-upon compensation for each instance in which the guaranteed level is not met, not guaranteed uptime

C. SLAs eliminate all risk

D. SLAs are not legally binding

Q64: Explanation

Correct Answer: B

Problems arise when managers have an imperfect understanding of how much risk the enterprise is taking on, such as mistakenly believing that an SLA ensures particular levels of uptime rather than ensuring agreed-upon compensation for each instance in which the guaranteed level is not met. A credit in the next billing cycle may not be a sufficient offset for an outage that puts the enterprise at risk of collapse.

Option Analysis

- **A** - **Incorrect:** SLAs provide compensation, not uptime guarantees
- **B** - **Correct:** SLAs ensure compensation, not uptime
- **C** - **Incorrect:** SLAs do not eliminate risk
- **D** - **Incorrect:** SLAs are legally binding

Q65: Risk Transfer and Reputation

Question

Why is risk transfer through cloud services or insurance incomplete?

A. Because contracts are always void

B. Because the enterprise retains the impact to its reputation in the event of loss

C. Because insurance companies never pay claims

D. Because risk cannot be transferred at all

Q65: Explanation

Correct Answer: B

The use of cloud services is a form of risk transfer for which the enterprise retains the impact to its reputation in the event of loss. A credit in the next billing cycle may not be a sufficient offset for an outage that puts the enterprise at risk of collapse. Stakeholders rarely regard the transfer of risk as complete absolution of blame.

Option Analysis

- **A - Incorrect:** Contracts are generally valid
- **B - Correct:** Reputational impact remains with the enterprise
- **C - Incorrect:** Insurers generally pay valid claims
- **D - Incorrect:** Risk can be transferred, but not completely

SDLC & Resilience Key Takeaways

Essential Concepts

- SDLC provides a structured approach to manage systemic risk
- Security must be built in early—it is cheaper and more effective
- Project risk (on time/budget) differs from system risk (meets needs)
- Agile delivers better business value; Waterfall enables better cost control
- Parallel changeover is safest; Abrupt is riskiest
- Data life cycle: create, store, use, share, archive, destroy
- Allowlists are preferred for static data validation
- DLP false positives disrupt workflows; false negatives allow leaks
- Cloud shifts recovery responsibility to providers—enterprises must document and accept the risk

Final Advice

Exam Preparation

Remember:

- Understand the *why* behind each technology risk concept
- Know the difference between similar terms
- Understand how emerging technologies introduce new risk
- Practice scenario-based questions
- Use the ISACA mindset

Good Luck on Your CRISC Exam!